

Guide d'entretien ; Responsable technique / Développeurs

Informations générales

Mission :

Date : **Heure :** **Durée prévue :** 60–90 min

Interlocuteur : **Fonction :**

Preuves demandées : Code source (extraits), configurations, journaux de build, procédures de déploiement

Thème 1 : Cycle de développement sécurisé

#	Question	Preuve attendue
1.1	Les exigences de sécurité sont-elles définies avant le développement de chaque fonctionnalité ?	Cahier des charges, user stories
1.2	Des revues de code intégrant des critères de sécurité sont-elles menées ?	Historique de revues
1.3	Des outils d'analyse statique (SAST) sont-ils intégrés dans le pipeline ?	Rapports SonarQube ou équivalent
1.4	Les environnements de développement, test et production sont-ils séparés ?	Architecture des environnements
1.5	Les données de test sont-elles anonymisées ?	Scripts d'anonymisation

Thème 2 : Gestion des vulnérabilités et mises à jour

#	Question	Preuve attendue
2.1	Un inventaire des bibliothèques tierces utilisées dans GIDOCEP existe-t-il ?	Fichier de dépendances (pom.xml, requirements.txt...)
2.2	Ces bibliothèques sont-elles vérifiées régulièrement pour des vulnérabilités connues ?	Rapport de scan de dépendances
2.3	Quelle est la procédure d'application des correctifs de sécurité ?	Procédure de patch management
2.4	Des tests de régression sécurité sont-ils menés après chaque mise à jour ?	Rapports de tests

Thème 3 : Gestion des accès et authentification

#	Question	Preuve attendue
3.1	Comment les mots de passe sont-ils stockés dans GIDOCEP ?	Extrait de code (hachage)
3.2	Quelle est la politique de gestion des sessions (expiration, invalidation) ?	Configuration de session
3.3	Le principe de moindre privilège est-il appliqué dans les niveaux d'accès ?	Matrice des droits
3.4	Comment les comptes administrateurs sont-ils gérés et surveillés ?	Procédure de gestion comptes admins

Thème 4 : Journalisation et traçabilité

#	Question	Preuve attendue
4.1	Quels événements sont journalisés dans GIDOCEP ?	Configuration de journalisation
4.2	Les journaux sont-ils protégés contre la modification ou la suppression ?	Contrôle d'accès aux logs
4.3	Quelle est la durée de conservation des journaux ?	Politique de rétention
4.4	Les journaux sont-ils surveillés activement ou analysés périodiquement ?	Procédure de surveillance

Thème 5 : Logique métier GIDOCEP

#	Question	Preuve attendue
5.1	Le workflow de validation des écritures comptables est-il implémenté côté serveur exclusivement ?	Extrait de code
5.2	Est-il possible de modifier une écriture comptable après validation ? Si oui, comment est-ce tracé ?	Log d'audit des modifications
5.3	Des contrôles empêchent-ils la saisie d'écritures hors-période comptable ?	Code de validation + test
5.4	La séparation des données entre établissements est-elle garantie ? Comment ?	Architecture multi-tenant
5.5	Existe-t-il des contrôles sur les montants maximaux saisissables ?	Configuration des limites

Thème 6 : Infrastructure et configuration

#	Question	Preuve attendue
6.1	Le serveur hébergeant GIDOCEP est-il dédié ou partagé avec d'autres applications ?	Architecture serveur
6.2	Les communications entre GIDOCEP et sa base de données sont-elles chiffrées ?	Configuration de connexion
6.3	Les sauvegardes sont-elles automatisées, chiffrées et testées régulièrement ?	Procédure + log de sauvegarde
6.4	Quels composants logiciels (OS, serveur web, BDD) sont utilisés et dans quelles versions ?	Inventaire technique